

A. Preamble

Contact name: Joseph Motta
Contact title: Red Team Lead
Contact email: jrm9960@nyu.edu
Contact phone #: (845)-242-2721

Date: 3/9/2026

Subject: Request for Proposal (RFP) for External and Internal Penetration Testing Services

Official Proposal

Near-Earth Broadcast Network



B. Table of Contents

C. Executive Summary	3
D. Introduction	4
• About Us	4
• Objectives	4
• Approach	4
• Roles	5
• Schedule	5
• Cost	6
E. Scope of Work	7
• Targets	7
○ External network	
○ Internal network	
○ External web applications	
• Rules of Engagement	8
• Findings	8
• Assumptions	8
F. Methodology	9
• Testing	9
• Steps	10
• Risk scoring methodology	11
G. Deliverables	13
• Conclusion	13
• Deliverables	13
• Example report template	14
H. Appendixes	16
• A: Tools	16
• B: References	16
• C: Glossary	16
• D: Questions for NBN CISO	17

C. Executive Summary

Near-Earth Broadcast Network (NBN) has requested a penetration test to evaluate the security of its IT infrastructure. The goal is to determine potential attack paths, how they may be exploited, and the resulting impact on business processes and assets. This will inform NBN of weaknesses that could affect the confidentiality, integrity, and availability of NBN user data and systems.

This will be a black box penetration test – in other words, from the perspective of an outside attacker with no knowledge of or access to NBN systems. The scope will encompass NBN’s external networks, external web applications (NBN TVee, NBN ADs, NBNHelp), and ideally internal networks if the external networks prove to be weak. Per the RFP, we aim to identify weaknesses with the greatest impact on NBN business processes, specifically weaknesses that have at least a “Medium” severity rating. Per the RFP, **we will not:**

- Test the 3rd party VPN used by employees
- Test physical security
- Exploit existing Sub/BP accounts
- Execute Distributed Denial of Service attacks (DDoS)

The result of this test will be a comprehensive report that describes all our findings, their associated business risks, and suggested fixes to minimize said risk. Addressing the findings in the report will improve NBN’s security posture, increase user trust, secure sensitive information, support compliance, reduce legal liability, and avoid reputational damage. The price of this penetration test is significantly lower than the reputational and financial damage resulting from a breach.

D. Introduction

About Us

JM Cybersecurity Consulting is a penetration testing firm that specializes in black box testing for medium-large size companies. We have a proven track-record in identifying high risk vulnerabilities in both networks and applications. Our penetration testing services are adept in both ensuring compliance and preventing reputational and financial loss. We use a multi-phase approach to ensure thorough work, and we believe that preparation is the most important step.

In this proposal, we outline our services that we have to offer in alignment with the RFP: we plan on conducting external/internal network testing as well as external application testing.

Objectives

In our penetration test, our goal is to simulate an attacker trying to gain unauthorized access to hosts, services, and network systems within NBN's IT infrastructure. This will be a black box penetration test where the attacker has no knowledge of NBN's internal or external systems, and has no access to networks, systems, physical locations, or IT infrastructure. At the conclusion of testing, we will generate a report consisting of discovered vulnerabilities with severity rankings based on their exploitability and impact on confidentiality, integrity, and availability – in the context of NBN's business goals. Remediations will be suggested for each of the discovered vulnerabilities. Overall, this test will determine NBN's cybersecurity risks for outside threats and what can be done to minimize this risk. The high-level targets for this penetration test are the following:

- **Internal network**
- **External network**
- **External web applications**

Approach

For each of the above, we will use a multi-phase approach consisting of:

- **Reconnaissance:** A variety of tools and techniques will be used to develop a list of targets (hosts, services, and people) to be scanned, assessed for vulnerabilities, and eventually exploited.
- **Scanning and Vulnerability Enumeration:** The objective of this phase is to gain an understanding of the identified targets with regards to active services, versions, OSs, and existing security countermeasures. A combination of active and passive scanning techniques will allow us to build a list of existing vulnerabilities to be exploited.
- **Vulnerabilities and Exploitation:** Now that we have an idea of existing vulnerabilities, we will attempt to exploit them to deliver payloads with the overarching goal of executing code on remote hosts. This will be done by using known exploits for documented vulnerabilities as well as manually developing exploits. A variety of tools will be used in exploitation which can be found in the methodology section and will also be listed in the final report. If exploitation of the external network leads to internal network access, the penetration test will pivot to internal vulnerability enumeration and exploitation. The exploitation phase will eliminate false-positive vulnerabilities and demonstrate their business risk, allowing us to assign them a severity rating. The full exploitation process will be documented so that they may be recreated.
- **Post-Exploitation:** If a vulnerability is successfully exploited, we will continue testing in the environment to move laterally, escalate privileges, and overall determine what an attacker could be capable of. This will further demonstrate the business impact of vulnerabilities if they are successfully exploited by an attacker.

- **Reporting and Remediation:** Throughout the entire penetration testing process, we will document the targets, steps taken, tools used, and techniques that led to vulnerability enumeration and exploitation. Our exact findings will be documented where vulnerabilities will be given severity ratings using the CVSS framework, and then further given risk ratings using the NIST SP 300-80 process and a risk scoring matrix. These vulnerabilities will be ranked in order of importance, and we will suggest remediations for each one. Our findings will focus on vulnerabilities with severity ratings of “Medium” or higher according to the RFP guidelines. However, all findings regardless of severity will still be documented, ranked, and paired with a suggested remediation.

Roles

- **Red Team Lead – Joseph Motta**
 - Responsibilities:
 - Plans penetration testing strategy
 - Coordinates testing activities
 - Oversees project scope
 - Oversees documentation and reporting
- **Security Analyst – Joseph Motta**
 - Responsibilities:
 - Performs reconnaissance and scanning
 - Analyzes vulnerabilities
 - Exploits vulnerabilities
 - Documents results
- **Project Manager – Joseph Motta**
 - Responsibilities:
 - Communicates with stakeholders
 - Manages timeline
 - Oversees deliverables
 - Ensures deliverables are up to stakeholder specification and complete on time
- **Client Security Contact – Bill Gibson (CISO)**
 - Responsibilities:
 - Represents NBN
 - Approves scopes and ROE
 - Monitors testing
 - Receives final deliverables

Schedule

Phase	Date
Planning and Scoping	4/28 - 4/29 (2 days)
Reconnaissance	4/30 - 5/1 (2 days)
Scanning and Vulnerability Enumeration	5/2 - 5/4 (3 days)
Vulnerabilities and Exploitation	5/5 - 5/7 (3 days)
Reporting and Remediation	5/8 - 5/11 (4 days)
Completion Date	5/11 (Total = 14 days)

Cost

The cost of this penetration test is based on the amount of time needed to complete each phase of the test (see schedule). We estimate the time required to complete each phase and compile a report to be 14 days.

Our standard rate for a penetration test is \$2000 per day. This figure takes into consideration the time of our experienced consultants, the cost of the tools we use, as well as the effort put into compiling a report.

- Our standard cost of consulting is \$2000/day
- The completion of all phases sums to 14 days
- **Total cost: \$2000/day * 14 days = \$28,000**

This cost includes every phase of the test, analysis of all vulnerabilities, and a detailed report documenting all steps taken, findings, and suggested remediations.

E. Scope of Work

Targets

The following environments and assets are within scope. Per the RFP, anything not explicitly mentioned below may still be tested as long as it does not violate the ROE.

1. External Network

The external network testing will target any infrastructure owned or operated by NBN. We will target any internet facing hosts, exposed services, and network infrastructure that support NBN's external web applications. We will act as an unauthenticated attacker attempting to enumerate vulnerabilities in external systems.

Assets in Scope:

- Public IP Addresses (IPv4/IPv6)
- Internet-Facing Hosts supporting NBN applications
- Externally Accessible Services
- Domains and Subdomains
- Security Controls (firewall rules, network segmentation, IDS/IPS, rate limiting)

2. Internal Network

If the external network testing results in access to NBN's internal network, the test will pivot to internal network testing. The goal is to simulate post-exploitation attacker behavior to determine the impact of compromise within the internal infrastructure.

Assets in Scope:

- Internal Application Infrastructure
- Database Systems
- Internal Network Services
- Infrastructure systems
- Security Infrastructure

3. External Web Applications

The following externally available web applications owned by NBN will be evaluated for security vulnerabilities. Testing will focus on application logic, authentication mechanisms, API interactions, data exposures, and vulnerabilities described in OWASP Top 10.

These applications are publicly accessible from the internet and therefore represent a large portion of NBN's attack surface:

- **Subscriber Web Application "NBN TVee"**

- Web (browser) version
- Mobile Version

Note: Both versions share the same back-end APIs and architecture, which will be assessed during testing.

- **Business Partner Web Application "NBN ADs"**

- Web (browser) version

- **Support Application "NBNHelp"**

Note: NBN provides no email or phone support services.

- **Shared Backend APIs:**

- All NBN web applications share the same backend APIs hosted within NBN's infrastructure. These APIs facilitate communication between external web applications and internal application servers. These APIs will be evaluated for authentication, authorization, input validation, and data exposure vulnerabilities.

Assets in Scope:

- Web application interfaces
- Authentication and session management mechanisms
- API endpoints and backend services
- API authorization and authentication controls
- Input validation and injection vulnerabilities
- Rate limiting and abuse protection mechanisms
- Data handling and authorization controls
- Account management functionality
- Password reset mechanisms
- Role-based access controls

Rules of Engagement (ROE)

- Testing of the 3rd party VPN utilized by NBN employees is prohibited
- Physical security testing is prohibited
- Exploitation of existing Sub/BP accounts is prohibited
 - No data exposure of existing users
 - No compromising of existing accounts
 - In the event of accidental exposure to user data, we will promptly meet with NBN executives to discuss proper handling and secure disposal of the exposed data
- Distributed Denial of Service attacks (DDoS) are prohibited
 - In the event of accidental DDoS, we will promptly meet with NBN executives to decide next steps in restoring network functionality

Findings

Our testing will focus on discovering and exploiting vulnerabilities that have a severity rating of medium or higher. The severity rating will be determined based on business impact and financial loss. For each vulnerability exploited, we will provide rationale for the severity rating using the context of NBN's business goals. Per the RFP, exploits that only compromise a single account will automatically be designated as "Low" severity. Any vulnerabilities that are purely theoretical, as well as suggested best practices, will be included in the findings but receive "Low" severity ratings.

Assumptions

- NBN infrastructure is reachable from the internet.
- No documentation describing NBN will be provided.
- NBN staff will be available in the case of accidental DDoS, user data exposure, or user account compromise.

F. Methodology

Testing

This penetration test will follow industry-standard penetration testing frameworks such as Penetration Testing Execution Standard (PTES) and OWASP Web Security Testing Guide. The WSTG provides a structured process for identifying and analyzing vulnerabilities, namely the OWASP Top 10 that we are focusing on. These frameworks provide a structured approach to discovering, validating, and exploiting vulnerabilities within both network and application environments. Testing will be done from the perspective of an outsider with no knowledge of the environment.

External Network Penetration Test

This test is designed to assess the security of NBNs' publicly accessible infrastructure. The goal is to determine vulnerabilities in externally facing hosts and services that could allow an attacker to gain unauthorized access to internal systems.

Tests will include:

- Host discovery (ping sweep)
- Network tracing
- Service + version scanning
- OS fingerprinting
- Service vulnerability analysis
- Misconfiguration discovery
- Exploitation of exposed services

External Application Penetration Test

This test will evaluate the security of NBN's external web applications: NBN TVee, NBN ADs, and NBNHelp. The goal is to identify vulnerabilities in application logic, authentication mechanisms, input validation, and API interaction.

Testing will follow OWASP Web Security Testing Guide

Tests will include:

- Authentication security testing
- Authorization and access control testing
- Session management testing
- Input validation and injection testing
- API security testing
- Data exposure risks
- Business logic vulnerabilities

Internal Network Penetration Test:

If the external network penetration test gives us access to the internal network, we will pivot to determine the impact of successful exploitation.

Tests will include:

- Internal host discovery
- Service enumeration
- Credential harvesting attacks
- Privilege escalation
- Lateral movement

- Access to sensitive systems or data

Steps

The penetration test will contain the following phases:

1. Reconnaissance

Consists of building a list of targets (people, applications, and hosts) to be scanned, assessed, and exploited. This is done by gathering publicly available information using the following techniques/tools:

- Open-Source Intelligence Gathering (OSINT)
 - Google Hacking
 - Company websites
- Passive network reconnaissance
 - Domain name recon (whois)
 - IP address assignment (Regional Internet Registries)
 - ARIN search
 - NSlookup
 - Shodan

2. Scanning and Vulnerability Enumeration

This phase falls between reconnaissance and weaponization. Our goal is to learn as much as possible about the target, including live hosts, OSs, network architecture, and open ports/services so that we can determine vulnerabilities and understand the exploits and how to deliver them. We will use a combination of active and manual techniques to garner an understanding of existing vulnerabilities, including:

- Nmap
 - Firewall spotting
 - Probing
 - Ping sweep
 - Network tracing
 - Port scanning
 - Version scanning
 - OS fingerprinting
- TCPDump
 - Monitoring scans
- Traceroute
 - Determining hops to a target
- Netcat
 - Listening/connecting to remote hosts
- Recon-ng
- DNS cache snooping

3. Vulnerabilities and Exploitation

After discovering vulnerabilities, we will exploit them in this phase. This will remove false positives, lead to pivoting and therefore more vulnerabilities, and demonstrate the business risk of exploitation. Our ultimate goal is to get a running payload on a remote system. There are server-side exploits (active) and client-side exploits (passive). The following techniques and tools will be used:

- Metasploit
- MSFVenom/Veil Framework

- Exploiting browsers and plugins, office apps, runtime environments
- Bind/Reverse shells
- Hosting exploit over the network, followed by a phishing campaign (client side)
- Anti-virus evasion:
 - Ghostwriting
 - Encoding
 - Direct to memory
 - Custom compiling
- Reverse engineering/fuzzing
 - Buffer overflow

4. Post-Exploitation

If we manage to compromise a system, we will facilitate additional testing to determine the impact within the environment. Our potential activities will include:

- Privilege escalation
- Lateral movement
- Access to internal systems
- Data access evaluation

5. Reporting and Remediation

All vulnerabilities will be recorded, analyzed, and the most relevant ones will be exploited. Vulnerabilities will be ranked and prioritized based on likelihood and impact. We will also provide suggested remediations for each vulnerability.

Risk Scoring Methodology

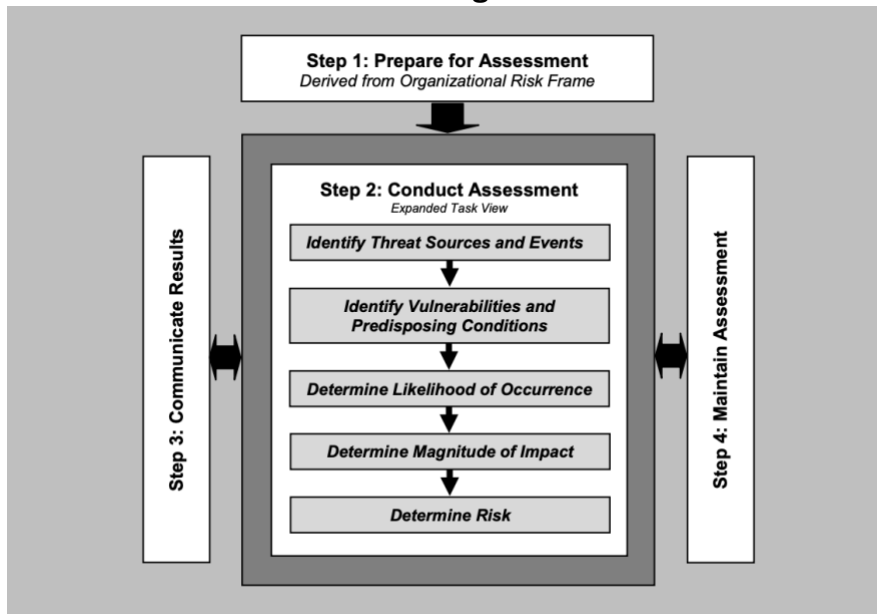
Identified vulnerabilities will be assigned a severity rating based on the Common Vulnerability Scoring System (CVSS). This framework will provide a standardized way to measure severity based on Exploitability, Impact on confidentiality, Impact on integrity, Impact on availability, Ease of exploitation, and Level of access required.

Severity levels will be categorized as follows:

Severity	CVSS Score Range	Description
Critical	9.0-10.0	Extremely severe risk that must be addressed immediately.
High	7.0-8.9	Very dangerous risk with a high chance of resulting in a breach.
Medium	4.0-6.9	Moderate security weakness that is recommended to be addressed
Low	0.1-3.9	Minor issue with limited security impact.
None	0.0	Deemed to have no risk.

However, CVSS severity level is only half of the picture. We will need to take that raw technical severity score and put it into the context of likelihood within the environment and the business impact with regards to assets. This will be done by following the NIST SP 300-80 risk assessment guide and taking the CVSS severity score into consideration. This will result in a relevant, contextualized risk score for each vulnerability, allowing us to effectively rank them in order of importance to NBN.

NIST SP 300-80 risk assessment guide that we will follow:



Likelihood of Occurrence will be determined by:

- CVSS score
- Effort required from attacker
- System reachability
- Exploit availability

Magnitude of Impact will be determined by:

- CVSS score
- Importance of asset
- Data sensitivity
- Business process disruption

By following that risk assessment guide, we will be able to map vulnerabilities onto the following **risk gradient matrix**:

		<i>Impact</i> →				
		Negligible	Minor	Moderate	Significant	Severe
<i>Likelihood</i> ↑	Very likely	Low - Medium	Medium	Medium - High	High	High
	Likely	Low	Low - Medium	Medium	Medium - High	High
	Possible	Low	Low - Medium	Medium	Medium - High	Medium - High
	Unlikely	Low	Low - Medium	Low - Medium	Medium	Medium - High
	Very unlikely	Low	Low	Low - Medium	Medium	Medium

By using industry standard frameworks to combine purely technical vulnerability severity ratings with a context-based approach that understands asset importance, business processes, and the environment being tested, we will provide a risk score ranging from “Low” to “High” that is relevant to the goals of NBN from a business standpoint.

Note: Per the RFP, attacks that compromise a single account will automatically be designated as “Low” risk; information-only, suggested best practices, and theoretical-only exploits will also be automatically designated as “Low” risk. Although NBN is interested primarily in exploits with severity “Medium” or higher, we will document all vulnerabilities regardless of severity level and suggest remediations.

G. Deliverables

Conclusion of penetration test

At the end of the penetration test, we will stop all testing and document our findings to be analyzed. In the analysis process, we will review all vulnerabilities and evaluate the overall security posture of NBN's IT infrastructure.

Post-testing, the following will occur:

- Classification of vulnerabilities based on severity score
- Ranking of vulnerabilities in order of priority
- Finalize documentation of steps to exploit vulnerabilities so that NBN can recreate them
- Develop a comprehensive penetration testing report
- Reconvene with NBN stakeholders to share most important findings and recommendations

Deliverables

Upon completion of the testing, NBN will receive a penetration testing report that contains all findings and recommendations. This will include:

1. Executive Summary

A summary of the penetration test that highlights the most significant findings, recommendations, and business risks and is intended for management and non-technical personnel.

2. Introduction

This provides a detailed overview of the test; this will include test goals, objectives, and our overall methodology. It will explain the types of tests we chose to use and why. It will also include the timeline of the penetration test. Lastly, the introduction outlines the consultants involved, the overall risk, and high-level findings.

3. Methodology

In detail, describes the process for testing and results of each one: intel, recon, scanning, vulnerability enumeration, and exploits. The methodology will provide each system that was targeted and what was done for each one. We will also provide a list of tools we used and the exact steps to take to recreate the results we provided.

4. Findings

This section lists all findings in a chart with the vulnerability, host, and risk. Each vulnerability will be broken down into a technical description, method of discovery and exploitation, impact to assets, risk rating and calculations, and remediation recommendation. It will contain screenshots of critical information that we discovered during the discovery and exploitation process.

5. Conclusion

The conclusion contains no new information and instead summarizes the project, tests, scope, targets, and reiterates the risk. We will make the impact of our findings and the suggested remediations clear.

6. Appendixes

The appendixes consist of long lists, results, raw tool outputs, pre-test documents (legal), the target list, and vulnerability scanner outputs.

Example Report Template

Near-Earth Broadcast Network (NBN)

JM Cybersecurity Consulting

Date: XXXX

EXECUTIVE SUMMARY

This penetration test evaluated the security of NBN's external network infrastructure and publicly accessible web applications. The test was carried out as if JM Cybersecurity Consulting was an external attacker with zero prior knowledge of the environment.

The assessment identified vulnerabilities that could allow unauthorized access to systems or sensitive subscriber data.

Key Findings

Severity	Count
Critical	X
High	X
Medium	X
Low	X

Key Recommendations

- Restrict unnecessary external access
- Improve authentication and access controls
- Use stronger input validation inside of web applications

INTRODUCTION

This report contains the results of the penetration test conducted against NBN IT infrastructure.

Objectives

- Identify vulnerabilities in external network services
- Evaluate the security of NBN web applications
- Measure the business impact

Scope

- External Network Infrastructure
- External Web Applications (NBN TVee, NBN ADs, NBNHelp)
- Internal Network

Timeline

Phase	Date
Reconnaissance	X
Testing	X
Reporting	X

METHODOLOGY

Testing followed industry standards including the Penetration Testing Execution Standard (PTES) and the OWASP Web Security Testing Guide.

Testing Phases

1. Reconnaissance
2. Scanning and Vulnerability Enumeration

3. Vulnerabilities and Exploitation
4. Post-Exploitation
5. Reporting and Remediation

Tools Used

- Nmap
- Netcat
- Metasploit
- SQLmap

FINDINGS

Vulnerability Summary

ID	Vulnerability	Host	Severity
V-01	SQL Injection	Nbnexample.com	High
V-02	Weak Authentication	Nnb.nbn.com	Medium

Example Finding:

Vulnerability: SQL Injection

Host: nbnexample.com

Severity: High

Description: Lack of parameterized inputs, allowing SQL injection

Impact: Attackers may retrieve, alter, or delete sensitive subscriber data.

Recommendation: Use parameterized queries and input validation.

CONCLUSION

The penetration test identified vulnerabilities that have adverse business impacts due to compromised assets. Addressing the findings in this report will substantially improve NBN's security posture regarding external threats.

We recommend further security testing and monitoring.

APPENDIXES

Appendix A – Tools

Tools used during the pen testing process

Appendix B – Raw outputs

Scanner results and other raw outputs

Appendix C – Evidence

Screenshots and other proof of successful exploitation

H. Appendixes

Appendix A: Tools

- Nmap
- Netcat
- Whois
- DNS Lookup
- ARIN
- Shodan
- TCPDump
- Wireshark
- Meterpreter
- Metasploit
- MSFVenom
- Veil Framework

Appendix B: References

- CS-GY 6573 Slides and Video Modules: Weeks 1-6
- National Institute of Standards and Technology. (n.d.). *Common Vulnerability Scoring System (CVSS)*. National Vulnerability Database. <https://nvd.nist.gov/vuln-metrics/cvss>
- National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments (NIST SP 800-30 Rev. 1)*. <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf>
- OWASP Foundation. (n.d.). *OWASP Web Security Testing Guide (WSTG)*. <https://owasp.org/www-project-web-security-testing-guide/>
- Chicago Teachers' Pension Fund. (2023). *Data consultants*. https://ctpf.org/sites/files/2023-10/data_consultants.pdf
- Penetration Testing Execution Standard (PTES). (n.d.). *The Penetration Testing Execution Standard*. <http://www.pentest-standard.org>
- NESEC GmbH. (n.d.). *NESEC – Gesellschaft für angewandte Netzwerksicherheit*. <https://www.nesec.de/en/>

Appendix C: Glossary

- **Black box testing:** A type of penetration test where the testers lack any knowledge of the testing environment to simulate an external attacker.
- **Exploit:** An exploit is code that is used to take advantage of a vulnerability to in turn deliver a payload or cause some otherwise unintended action.
- **Payload:** This is code that is delivered via an exploit usually to set up a communication channel or remotely execute code – what you typically think of when something is “hacked”.
- **Post-exploitation:** This consists of different actions an attacker will perform after gaining initial access to actually affect assets.
- **Host-discovery:** This is the process of determining that active hosts running on a network.
- **Service Enumeration:** This is the process of determining the active services, and their versions, that are running on hosts within a network.

- **OS Fingerprinting:** Using certain tools and techniques to determine the operating system that is running on a host.
- **Privilege escalation:** When attackers increase their privileges on a system despite being unauthenticated.
- **Lateral movement:** Jumping from one host to another on a network.
- **Authentication:** Verifying the identity of a user.
- **Authorization:** Determining the privileges that a user should have, granted they have been authenticated.
- **Session management:** Securely tracking user activity in terms of authentication, authorization, and data exchange when they are using a web application.
- **Input validation:** Ensuring that a user does not try to put malicious data into an application's input fields.
- **API (Application Program Interface):** Rules and protocols that tell web applications how to communicate with each other.
- **Vulnerability:** A weakness in a system or applications design or configuration that can be taken advantage of by an attacker.
- **Likelihood:** The probability that an attacker will successfully exploit a vulnerability.
- **Impact:** The effect on assets that a successful exploit can cause.
- **Risk:** This is a rating of severity for a vulnerability that is a combination of both likelihood and impact.
- **OWASP Web Security Testing Guide:** This is an industry standard framework that gives a standardizes process for penetration testing web applications.
- **PTES:** This is an industry standard framework comprised of overall best practices for penetration testing.
- **NIST SP 800-30:** This is an industry standard framework for determining the risk rating of vulnerabilities.

Appendix D: Questions for NBN CISO

- Should NBN cybersecurity employees be made aware of our presence in case they detect malicious activity?
- Are there any specific hosts or services that we must avoid during testing?
- Which systems are most important to users and day-to-day operations?
- What are the regulations or compliance requirements that NBN must follow (if any)?
- Are there restraints on times when testing is permitted? To simulate a real-world threat, minimal restraints would be ideal.
- We mentioned earlier that in case of accidental DDoS or sensitive data exposure we will promptly meet with you, but what do procedures would you suggest for such an event?